

End-to-end web security — protocols overview

Ari Niemi
Department of Computer Science
University of Helsinki, Finland
ari.niemi@helsinki.fi

ABSTRACT

Commercial transactions have become extremely common on the Internet. The World Wide Web is full of sensitive information. However, plain TCP/IP doesn't provide the security necessary for e-commerce, online banking and company extranets. Without the use of additional tools credit card numbers and passwords are easily available to extraneous people.

End-to-end web security solutions try to enhance the situation. A number of cryptographic protocols have been proposed and specified to provide confidentiality, integrity, authentication and availability on the Internet. They vary for example in their locations with respect to the TCP/IP protocol stack. Both lower layer and higher layer implementations have their pros and cons.

In this paper, four security protocols are introduced, one for each layer I have chosen (data link, network, transport and application layer). Additionally, I will describe positive and negative aspects for implementing end-to-end security on each layer.

Keywords

End-to-end web security, protocols, TCP/IP, cryptography, data link layer, network layer, transport layer, application layer, PPTP, IPsec, SSL, SET

1. INTRODUCTION

The World Wide Web can be a dangerous place. Still many people don't know that their credit card number may not be safe when buying a DVD from a web store. Some of those web users, who do know the difference between normal and secure connections, do not necessarily recognize if the connection they are using is secure [8]. Additionally, some corporate managers might be willing to build and hurry an extranet for the clients of their company and because of the rush perhaps neglecting some of the security matters. In

that case, company's and its clients' sensitive information can fall into wrong hands.

Businesses and government agencies, not to mention many individuals, are nowadays eager to put up Web sites. Electronic commerce is becoming more and more popular way to trade. Security considerations like those mentioned in the previous paragraph also apply to many other transactions in the WWW such as financial activities. Some tools are needed to keep these transactions safe.

1.1 Security requirements

Traditional security categories found in the literature are suitable when considering WWW security. Confidentiality, integrity, availability (sometimes called just denial of service) and authentication [27] are requirements that can be aimed at World Wide Web services. Non-repudiation and access control [32] can also be added to the list.

Confidentiality means that information is not made available, disclosed or readable to unauthorized parties. This information can be for example data which is streaming on the Internet or data which is stored in a computer's memory. Losses of privacy and information are possible consequences when an attack against confidentiality is executed. Encryption is one countermeasure against threats of confidentiality.

Integrity can be defined so that data can not be altered undetected. For example, when email is received, the receiver notices if the email message has been modified after it has been sent by the original sender. File system modification is another type of attack against integrity of which a Trojan horse installation is an example. One can use cryptographic checksums to provide integrity.

Availability is a property which means that a system is available, accessible and provides resources for authorized users when they need it. A support web site of a company is an example of a service which should be available for customers all the time. Attacks against availability include flooding a server with multiple continuous service requests and filling up disk space. Firewalls and intrusion detection systems, for instance, help to maintain availability. Software updates play a great role also, because many denial of service attacks are executed through bugs in program code.

With authentication, the claimed identity of a principal is being verified. For example, a user of a company extranet

has to be authenticated before he or she can start to use the service. Thus, extraneous users can be kept away. Additionally, the service should authenticate itself to the user. Authentication can be provided with digital signatures and certificates.

Non-repudiation is a property that enables the receiver of a message to prove that the sender indeed did send the message even though the sender tries later to deny ever having sent it. This might happen, for instance, in electronic stock exchange when a customer subscribes for shares and later denies the whole dealing. The use of digital signatures prevents these kinds of actions.

Finally, access control can be found to be redundant with confidentiality, integrity and availability. However, it can be thought as prevention of unauthorized access to resources of a system.

Threats and attacks on the Internet can be categorized, for instance, as passive and active attacks and also in terms of the location of the threat [33]. Passive attacks are usually hard to detect because they leave little or no trace at all of their activity. Passive attacks include eavesdropping on network traffic between client and server, and gaining access to a restricted web site. In active attacks, the attacker is literally active taking part in the communication, for example, via modifying IP datagrams. Active attacks comprise IP spoofing, altering information on a web site and replay attacks. Speaking about the location, the threat can be aimed at web browser, web server or network traffic between those two entities.

There are a number of security protocols that have been proposed as countermeasures against threats in the WWW. Some of these cryptographic solutions try to provide end-to-end web security. Security protocols have been specified to operate on different layers on the TCP/IP protocol family. Implementation of a protocol on a particular layer has usually both good and bad aspects. For instance, implementing security on the network layer has such an advantage that it is transparent to end users. On the other hand, it might require extra processing overhead on network devices such as routers.

1.2 The TCP/IP protocol stack

The TCP/IP Internet Protocol Suite can be used to communicate across any set of interconnected networks. It is being used on many corporate intranets as well as on the Internet. The two main standards of TCP/IP are Transmission Control Protocol (TCP) [24] and Internet Protocol (IP) [23].

TCP/IP protocol family is organized into five conceptual layers. With layering one can manage the complexity of a protocol more easily and one designer can focus attention on one functional part at time. The TCP/IP layers are sometimes referred to as the TCP/IP protocol stack. This layered architecture is illustrated in figure 1 [3].

A layer on one machine communicates virtually directly with the same layer on another machine. For example, the transport layer on the sending machine sends a packet to the

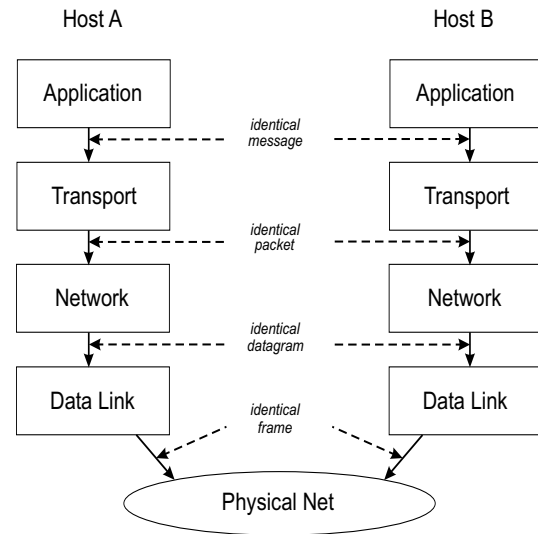


Figure 1: The TCP/IP layered architecture

transport layer on the receiving machine. Conceptually, sending a packet from transport layer on one entity to another means transferring the message down through consecutive layers of protocol software on the sender's machine, forwarding the packet across the network, and transferring the packet up through consecutive layers of protocol software on the receiver's machine. The layer at the destination machine receives exactly the same packet the layer at the sending machine sent. The communication between two application programs is oftentimes called end-to-end.

The rest of the paper is organized as follows. In section 2, Data link layer and Point-to-Point Tunneling Protocol are introduced. Section 3 consists of Network layer and IP Security protocol. Transport layer and Secure Socket Layer are illustrated in section 4. In section 5, I present the overview of Application layer and Secure Electronic Transaction. Finally, the last section is a brief summary.

2. DATA LINK LAYER

Different layers of the TCP/IP protocol stack contain similar and also dissimilar functions. Each layer uses, for instance, its own message and header formats.

Data link layer transmits IP datagrams over a specific network. Physical layer is the layer below the data link layer. It consists of network hardware. Examples of protocols specified to operate on the data link layer include Ethernet (IEEE 802.3), Token Ring (IEEE 802.5) and Point-to-Point Protocol (PPP) [30] which is a protocol for dial-up networking.

The data link layer has not been very popular as a base for implementing security. One reason might be that there are so many different protocols in use at the data link layer. Therefore, compatibility between different network protocols at the data link layer would cause problems. Even so, there are few protocols that operate at this layer. These include SILS which stands for Standards for Interoperable LAN/MAN Security (IEEE 802.10) and Point-to-Point Tunneling Protocol (PPTP).

2.1 Point-to-Point Tunneling Protocol (PPTP)

The Point-to-Point Tunneling Protocol [10] has been created by Microsoft Corporation and a group of networking product vendors. It allows the Point-to-Point Protocol to be tunneled through an IP network and the data payload encrypted providing confidentiality and authentication. This enables the creation of a virtual private network (VPN), for example, to a private corporate intranet. PPTP can be used to connect a remote client to a Remote Access Server (RAS) located on a corporate intranet as well as to connect a computer connected to a local area network (LAN) to another LAN. In the former case, for instance, a European laptop user could be in the USA where she wants to connect to her corporate network which is located in Europe. First she makes a PPP connection to some ISP's dial-up server in the USA. Then she creates a VPN connection to the corporate intranet using PPTP. Now, the PPP frames are carried through the TCP/IP Internet to the corporate PPTP server.

There are two parallel connections in PPTP: a control connection and a PPTP tunnel. The control connection is used to query status and to convey signaling information between the client and the PPTP server. The PPTP tunnel is used to exchange the actual data (PPP frames) between the communicating entities. PPP uses an extended version of Generic Routing Encapsulation (GRE) [11] to carry user PPP frames. GRE packet is then encapsulated inside an IP datagram which is routed through the Internet. Figure 2 shows an example of a GRE/PPTP packet. The PPP payload part can be encrypted.

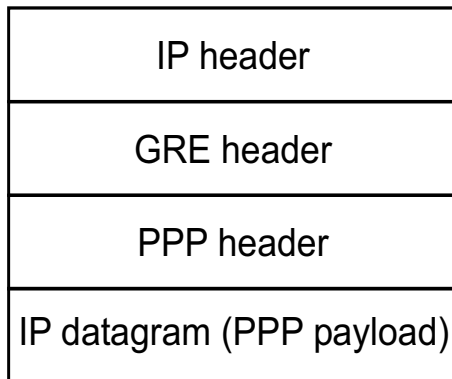


Figure 2: A PPTP packet

PPTP does not specify specific cryptographic algorithms but it provides a framework for the negotiation of those algorithms. The negotiation relies upon PPP Compression Control Protocol (CCP) [26], the Challenge Handshake Authentication Protocol (CHAP) [31] and the PPP Encryption Control Protocol (ECP) [19] among others.

For example, Microsoft's implementation of PPTP supports authentication and encryption. It uses Microsoft Point-to-Point Encryption (MPPE) [21] to encrypt PPTP packets. Authentication can be provided with clear password, hashed password (Windows NT hash function) or Microsoft's version of the CHAP protocol. However, Microsoft's PPTP has been proven to be insecure and vulnerable to attacks against both confidentiality and authentication [28].

3. NETWORK LAYER

The duty of the network layer is to route IP datagrams from sending host to receiving host through an internet. Internet Protocol (IP) [23] is the most used protocol at the network layer.

Implementing security at the network layer has multiple advantages. For example, confidentiality and integrity of network packets are guaranteed for every applications running on top of the TCP/IP stack. Therefore, applications do not have to implement security of their own. Network level security is also transparent for end users, so they don't have to change anything in order to take advantage of security mechanisms. On the other hand, application specific security functions cannot be implemented at the network layer, which is a disadvantage. Network layer performance might also decrease, because security functions are almost necessarily implemented in software [17]. Thus, processing overhead might emerge in both routers and hosts.

3.1 IP Security (IPSec)

IP Security [15] is a security protocol, which operates at the network layer. Its specification is quite complex; it is specified by a set of RFCs (Request For Comments), namely RFCs 2401 to 2411 and 2451 [12]. IETF developed IPSec due to the needs of a secure Internet. It covers all security requirements mentioned in the first chapter.

IPSec works with both IPv4 [23] and IPv6 [5] and in IPv6 it is a mandatory component. Authentication Header (AH) [13] and Encapsulating Security Payload (ESP) [14] are two components of IPSec that are added to the plain Internet Protocol to meet the security requirements. Both mechanisms add a new header to the IP datagram.

The authentication header guarantees data integrity and it authenticates the sending peer. It does not provide confidentiality. Message authentication code (MAC) is used in AH and the hash function is applied to the whole data part of the IP datagram and to non-mutable fields of the IP header. The result of the function is then stored inside a new header which is attached to the original IP datagram. A compliant AH implementation must support the HMAC [16] hash algorithm with MD5 or SHA-1 algorithms.

The encapsulating security payload provides confidentiality and optionally integrity and authentication. The original datagram is encrypted before it is sent. There are multiple encryption algorithms (e.g. DES, 3DES, IDEA) that can be employed of which DES in CBC mode is mandatory for any IPSec implementation. Both an ESP header and an ESP trailer are added to the encrypted original IP datagram.

IPSec can be used in two modes, namely, transport and tunnel modes. Transport mode provides protection primarily for upper layer protocols. It is used for end-to-end communication between two hosts. ESP encrypts and optionally authenticates the IP payload but not the IP header. AH authenticates the IP payload and non-mutable portions of the IP header. AH and ESP headers are inserted after the original IP header and before the IP payload. The ESP trailer is inserted after the IP datagram and after that the optional ESP authentication data field can be placed. Tunnel

mode protects the entire IP datagram. It creates a “tunnel” from one IP network to another, for example, between two routers or between a host and a router. In tunnel mode, a new IP datagram is created which includes a new IP header. The old IP header and payload are placed inside the new IP datagram. ESP encrypts and optionally authenticates the entire inner IP datagram including the inner IP header. AH authenticates the entire inner IP packet and non-mutable portions of the outer IP header. AH and ESP header are inserted between the new IP header and the old IP header. The ESP trailer is inserted after the IP datagram and after that the optional ESP authentication data field can be placed. Figure 3 shows the new datagram formats in the case of IPv4.

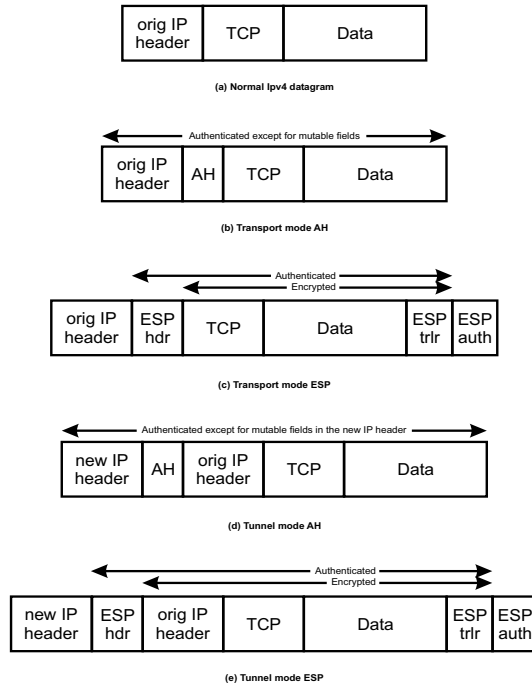


Figure 3: AH and ESP datagram formats in transport and tunnel mode in the case of IPv4

An important and fundamental concept in the IPsec architecture is the security association (SA). It is a one-way relationship between a sender and a receiver which contains all the necessary information for secured communication, such as negotiated encryption algorithms being used, encryption keys and their lifetimes, IPsec mode and source and destination addresses. For a two-way relationship, two SAs are needed. This is also the case when both AH and ESP are needed for communication. An SA is uniquely identified by three parameters: SPI (Security Parameters Index), destination IP address and security protocol (AH or ESP). SAs are kept in an SA database (SAD) and when a datagram is sent, its destination address is looked for in the SAD. If an entry is found, “norms” in that entry (i.e. SA) are followed to prepare the datagram. On the receiving entity, a security policy database (SPD) is used to decide whether the datagram is discarded or accepted.

As one can notice, secret keys are also an essential part of the IP Security. Communicating peers share secret keys and

there has to be a mechanism to create and distribute those keys to both entities. This can be done either manually or automatically. In small environments, it is easy to configure the keys manually. This can be done by a system administrator who installs the keys to machines in relationship. But in large environments, automatic configuration is more practical. For this purpose, ISAKMP/Oakley can be used. Oakley [20] is a key exchange protocol which is based on the Diffie-Hellmann algorithm. ISAKMP (Internet Security Association and Key Management Protocol) [18] provides a framework for Internet key management. Oakley is generic in that it does not set specific formats. ISAKMP provides specific protocol support, including formats, for negotiation of security attributes [33]. Keys are used to establish the SA before any secure communication can begin.

4. TRANSPORT LAYER

Transport layer provides communication between application programs. For instance, Transmission Control Protocol (TCP) [24] and User Datagram Protocol (UDP) [22] are transport layer protocols. In TCP/IP, TCP provides a reliable end-to-end byte stream.

Security protocols layered onto a TCP connection provide security to higher level protocols like HTTP [7] and IMAP [4]. An advantage to implementing security at the transport layer is that applications do not have to accomplish the tasks of encrypting and authentication. Instead, they can use, for instance, an API to secure communications. A downside comparing transport layer security to network layer security is that applications need more overhead in processing [2].

4.1 Secure Socket Layer (SSL)

Secure Socket Layer (SSL) [9], a transport layer security protocol developed by Netscape Communications Corporation, reached its version 3.0 in 1996. IETF’s Transport Layer Security (TLS) [6] is based on SSL 3.0, and although the two are not interoperable, implementations of TLS 1.0 are likely to support SSL 3.0.

SSL consists of two layers. At the lowest level is the SSL Record Protocol, which provides basic security services for higher layer SSL subprotocols. SSL Record Protocol is layered on top of some reliable transport protocol like TCP. Three higher layer protocols operate on top of the Record Protocol: Handshake Protocol, Change Cipher Spec Protocol and Alert Protocol. They provide support for SSL session establishment and management. Figure 4 illustrates the SSL architecture.

The SSL session and the SSL connection are two important concepts, which are defined in the SSL specification as follows:

- A **connection** is a transport (in the OSI layering model definition) that provides a suitable type of service. For SSL, such connection are peer to peer relationships. The connections are transient. Every connection is associated with one session.
- A **SSL session** is an association between a client and a server. Sessions are created by the Handshake Protocol. Sessions define a set of cryptographic security

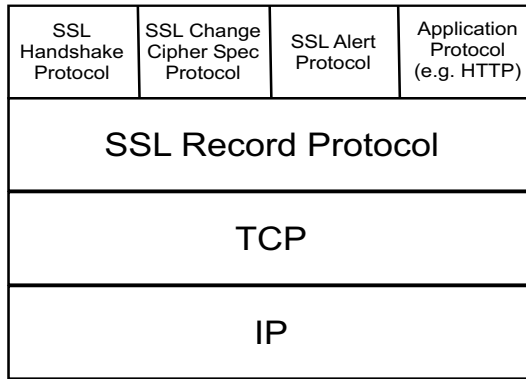


Figure 4: The layered protocol architecture of SSL

parameters, which can be shared among multiple connections. Sessions are used to avoid the expensive negotiation of new security parameters for each connection.

Data fragmentation, compression, authentication, encryption and preparing a header are functions of the SSL Record Protocol. The Record Protocol receives data from upper subprotocols and fragments that data into blocks (records) of 2^{14} bytes or less. After fragmentation, compression is applied, but it is not obligatory and, in fact, the default compression algorithm is null. By the SSL specification, the compression must be lossless and may not increase the content length by more than 1024 bytes. Next, a message authentication code is calculated over compressed data. A slightly modified version of the HMAC [16] algorithm is used to provide the MAC for each compressed fragment. After the creation of the MAC, the compressed fragment and the MAC are encrypted using symmetric encryption. Available algorithms include IDEA, 3DES and RC4 with key sizes varying from 40 bits to 168 bits. With authentication and encryption, the SSL Record Protocol provides confidentiality and integrity for SSL connections. The final task of the Record Protocol is to prepare a header for a fragment. The header includes four fields, which are Content type, Major version, Minor version and Compressed length. Content type specifies the higher layer protocol that should process the encrypted fragment. Version fields describe supported SSL versions. Compressed length field indicates the length of the compressed fragment in bytes.

The Change Cipher Spec Protocol consists of a single byte of value 1. It is used to update the cipher suite to be used on a connection.

The Alert Protocol is used to deliver SSL alert messages via the SSL Record Protocol. Warning and fatal are the two alert levels. Alert messages with the level of fatal result in immediate termination of the connection. Other connections on the same session may continue, but new connections are rejected. `Bad_record_mac` and `certificate_expired` are examples of SSL alerts.

The purpose of the third higher level subprotocol, the SSL Handshake Protocol, is to authenticate the client and the

server to each other and to negotiate cryptographic attributes to be used to protect data sent in an SSL record. The client and the server have to agree, for instance, on protocol version, compression method, MAC and encryption algorithms and they have to create a master secret, which is used to generate various cryptographic keys. Figure 5 shows the initial four steps of communication needed to establish a connection between the client and the server. After the handshaking, the client and the server may begin to exchange application data.

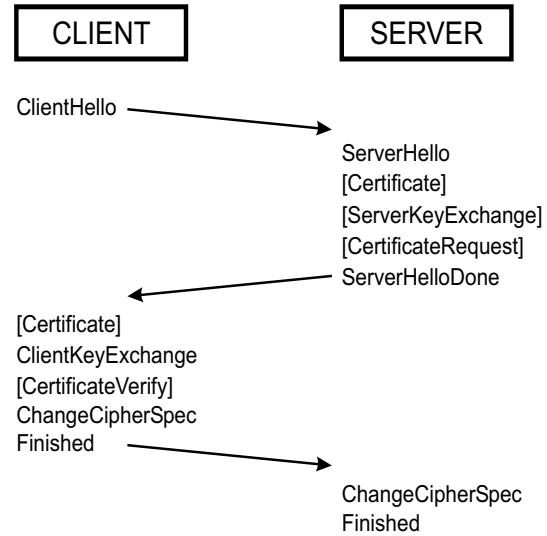


Figure 5: The messages in the SSL Handshake Protocol between the client and the server (messages in square brackets are optional)

In the first step, the client sends a ClientHello message, which includes client's SSL version number, a client generated random structure, session ID, cipher suite and compression method. Then the client waits for a ServerHello message, which contains the same fields. If server authentication is required, a Certificate message is sent by the server after the ServerHello message. The next message, ServerKeyExchange does not have to be sent by the server if the server has sent a certificate with fixed Diffie-Hellman parameters or if RSA key exchange is to be used. Next, a non-anonymous server can optionally request a certificate from the client with the CertificateRequest message if it is appropriate for the selected cipher suite. The final message of this second step is ServerHelloDone, which is a required message and indicates the end of this step.

In the beginning of the third step, the client sends a Certificate message to the server if server requested client authentication. Next is the ClientKeyExchange message, which is a required message. The content of it depends on the type of key exchange algorithm selected by the server. In the end of step three, the client may optionally send a CertificateVerify message to provide explicit verification of client's certificate. The fourth and last step begins with a ChangeCipherSpec message from the client to the server and after that, the client sends a Finished message. The Finished message is protected with the just-negotiated algorithms, keys and secrets. In response to these, the server sends its

own ChangeCipherSpec and Finished messages. After this, if no alerts have been interrupting, the SSL handshake is complete and a secure connection has been established.

5. APPLICATION LAYER

Application layer is on top of the stack at which users invoke application programs that access services available across a TCP/IP internet. An application interacts with a transport layer protocol to send and receive data. Hypertext Transfer Protocol (HTTP) [7] and Simple Mail Transfer Protocol (SMTP) [25] operate at the application layer.

An advantage of implementing security at the application layer is that internal security mechanisms of an application can be programmed to fulfill all the detailed needs of an application (e.g. protection of selected fields within a protocol) [1]. On the other hand, this creates overhead in processing and every application must have security mechanisms of its own.

5.1 Secure Electronic Transaction (SET)

Secure Electronic Transaction (SET) [29] is a security specification for credit card payments on the Internet. It is a series of security protocols and formats that enables users to make use of the existing credit card payment infrastructure on the Internet. It was announced 1996 by Visa International and MasterCard International. Many other companies took also part to the development of the standard (including IBM, Microsoft, Netscape and VeriSign). The SET specification is divided into three books and it contains 971 pages.

The following business requirements are listed in the SET specification:

1. Provide confidentiality of payment information and enable confidentiality of order information that is transmitted along with the payment information.
2. Ensure the integrity of all transmitted data.
3. Provide authentication that a cardholder is a legitimate user of a branded payment card account.
4. Provide authentication that a merchant can accept branded payment card transactions through its relationship with an acquiring financial institution.
5. Ensure the use of the best security practices and system design techniques to protect all legitimate parties in an electronic commerce transaction.
6. Create a protocol that neither depends on transport security mechanisms nor prevents their use.
7. Facilitate and encourage interoperability among software and network providers.

SET addresses these requirements by the following features:

- Confidentiality of information
- Integrity of data

- Cardholder account authentication
- Merchant authentication
- Interoperability

Confidentiality guarantees that cardholder account and payment information is secure as it travels through the network. Integrity means that transaction data cannot be altered unremarked. Concerning authentication, both the cardholder and the merchant must be able to verify each other. Interoperability points out that SET must be applicable on different hardware and software platforms with no preferences on any vendor or etc. However, SET provides only one choice for each cryptographic algorithm.

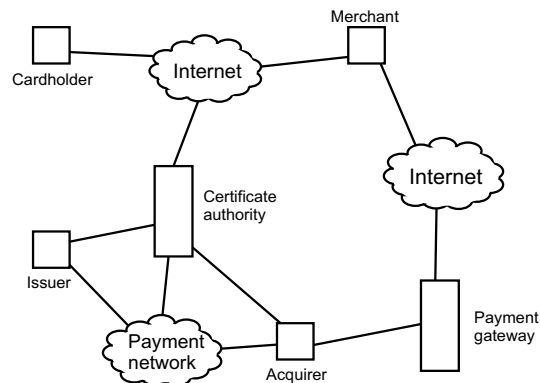


Figure 6: SET components

SET participants are shown in figure 6 [33] and they are detailed next. **Cardholder** is the purchaser who uses the credit card to pay to a merchant. **Merchant** offers goods for sale. **Issuer** is a financial institution, like a bank, that issues the payment card for the cardholder. **Acquirer** is also a financial institution that establishes an account with the merchant and processes payment card authorizations and payments. Thus, the acquirer checks, for instance, that the credit card is active and that the purchase does not exceed the credit limit. **Payment gateway** processes merchant payment messages. It can be operated by an acquirer or a designated third party. **Certification authority (CA)** is an entity to issue public-key certificates.

An important concept in SET is a dual signature. It links two messages that are intended for two different recipients. This way, the merchant does not see, for example, the actual credit card number of the cardholder's card. On the other hand, the acquirer will not find out what the cardholder is buying. Still, because of the link, the merchant knows that this payment belongs to this order. Thus, different orders don't get mixed up.

6. SUMMARY

Information in the WWW has to be secured if it isn't wanted to be read by outsiders. Additionally, one has frequently to be certain about the sender of a message and that nobody has not altered the message after it has been sent by the original sender. These and other security conceptions are addressed by several security protocols. End-to-end web

security can be provided by them to make web transactions safer.

7. REFERENCES

- [1] A. Bhimani. Securing the commercial internet. *Communications of the ACM*, 39(6):29–35, June 1996.
- [2] C. Blaafjell, M.-P. Lan, J. O’Dwyer, and H. J. D. Yang. A comparative analysis of IPsec and SSL.
- [3] D. E. Comer. *Internetworking With TCP/IP Vol I: Principles, Protocols, and Architecture, Fourth Edition*. Prentice Hall, Upper Saddle River, New Jersey 07458, USA, 2000.
- [4] M. Crispin. Internet Message Access Protocol - version 4rev1, RFC 2060. *IETF Internet Working Group*, December 1996.
- [5] S. Deering and R. Hinden. Internet Protocol, version 6 (IPv6), RFC 2460. *IETF Internet Working Group*, December 1998.
- [6] T. Dierks and C. Allen. The TLS protocol, version 1.0, RFC 2246. *IETF Internet Working Group*, January 1999.
- [7] R. T. Fielding, J. Gettys, J. C. Mogul, H. F. Nielsen, L. Masinter, P. Leach, and T. Berners-Lee. Hypertext Transfer Protocol, HTTP/1.1, RFC 2616. *HTTP Working Group*, June 1999.
- [8] B. Friedman, D. Hurley, D. C. Howe, E. Felten, and H. Nissenbaum. Users’ conceptions of web security: a comparative study. *Extended Abstracts of CHI 2002*, pages 746–747, April 2002.
- [9] A. Frier, P. Karlton, and P. Kocher. The SSL 3.0 protocol. *Netscape Communications Corp.*, November 1999.
- [10] K. Hamzeh, G. Pall, W. Verthein, J. Taarud, W. Little, and G. Zorn. Point-to-Point Tunneling Protocol (PPTP), RFC 2637. *IETF Internet Working Group*, July 1999.
- [11] S. Hanks, T. Li, D. Farinacci, and D. Traina. Generic Routing Encapsulation (GRE), RFC 1701. *IETF Internet Working Group*, October 1994.
- [12] G. Insolvibile. The IP Security protocol, part 1. *Linux Journal*, September 2002.
- [13] S. Kent and R. Atkinson. IP Authentication Header, RFC 2402. *IETF Internet Working Group*, November 1998.
- [14] S. Kent and R. Atkinson. IP Encapsulating Security Payload (ESP), RFC 2406. *IETF Internet Working Group*, November 1998.
- [15] S. Kent and R. Atkinson. Security architecture for the Internet Protocol, RFC 2401. *IETF Internet Working Group*, November 1998.
- [16] H. Krawczyk, M. Bellare, and R. Canetti. HMAC: Keyed-Hashing for Message Authentication, RFC 2104. *IETF Internet Working Group*, February 1997.
- [17] M. H. Linehan. Comparison of network-level security protocols. Technical Report RC 19632 (87068), 1994.
- [18] D. Maughan, M. Schertler, M. Schneider, and J. Turner. Internet Security Association and Key Management Protocol. *IETF Internet Working Group*, November 1998.
- [19] G. Meyer. PPP Encryption Control Protocol (ECP). *IETF Internet Working Group*, June 1996.
- [20] H. Orman. The OAKLEY key determination protocol. *IETF Internet Working Group*, November 1998.
- [21] G. Pall and G. Zorn. Microsoft Point-to-Point Encryption (MPPE) protocol, RFC 3078. *IETF Internet Working Group*, March 2001.
- [22] J. Postel. User Datagram Protocol, RFC 768. *IETF Internet Working Group*, August 1980.
- [23] J. Postel. Internet Protocol, RFC 791. *IETF Internet Working Group*, September 1981.
- [24] J. Postel. Transmission Control Protocol, RFC 793. *IETF Internet Working Group*, September 1981.
- [25] J. Postel. Simple Mail Transfer Protocol, RFC 821. *IETF Internet Working Group*, August 1982.
- [26] D. Rand. PPP Compression Control Protocol (CCP), RFC 1962. *IETF Internet Working Group*, June 1996.
- [27] A. D. Rubin, D. Geer, and M. J. Ranum. *Web Security Sourcebook*. John Wiley & Sons, Inc., New York, USA, 1997.
- [28] B. Schneier and Mudge. Cryptanalysis of Microsoft’s Point-to-Point Tunneling Protocol (PPTP). In *ACM Conference on Computer and Communications Security*, pages 132–141, 1998.
- [29] Secure Electronic Transaction LLC. Secure Electronic Transaction specification. Available at <http://www.setco.org/>.
- [30] W. Simpson. The Point-to-Point Protocol (PPP), RFC 1661. *IETF Internet Working Group*, July 1994.
- [31] W. Simpson. PPP Challenge Handshake Authentication Protocol (CHAP), RFC 1994. *IETF Internet Working Group*, August 1996.
- [32] W. Stallings. *Network and Internetwork Security*. Prentice-Hall, Inc., Englewood Cliffs NJ, USA, 1995.
- [33] W. Stallings. *Cryptography and Network Security: Principles and Practice (2nd edition)*. Prentice-Hall, Inc., New Jersey, USA, 1999.